



THE NATIONAL CERT OF **PAKISTAN**

L-Block, Pak Secretariat, Islamabad



Submitted By	Hafiz Muhammad Moawiz
Degree	BS - CY
Domain	Software Security Testing
Submitted To	Team NCERT

Network / Infrastructure Security — Recon & Scanning

Week 3 Task Report (31-7-2026)

#	Target URL/IP/Domain	Target Name	Status
1	192.168.32.132	Metasploitable2	Completed

1. Introduction

The target for this week was Metasploitable2, a Linux virtual machine that is deliberately built with old, insecure software so that it can be used for safe security practice. It was scanned from a separate Kali Linux virtual machine, with both machines placed on the same private lab network.

Lab Network Setup

Attacker Machine	Kali Linux — 192.168.32.131
Target Machine	Metasploitable2 — 192.168.32.132
Network	Both machines on the same private lab subnet, 192.168.32.0/24

Tools Used

Tool	What it was used for
Nmap	Discovering which hosts were alive on the network, and then scanning the target for open ports and the exact service/version running on each one
OpenVAS (Greenbone)	Running a full automated vulnerability scan against the target and generating a severity-ranked report

2. Network Reconnaissance

1. Confirming the Attacker Machine's Network

What we did: Before scanning anything, the Kali machine's own IP address and network range were checked, so the correct subnet could be scanned for other live hosts.

What we found: Kali's IP address was confirmed as **192.168.32.131**, on the **192.168.32.0/24** network.

```
(moawizz@moawizs-kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:fa:61:c4 brd ff:ff:ff:ff:ff:ff
    inet 192.168.32.131/24 brd 192.168.32.255 scope global dynamic noprefixroute eth0
        valid_lft 1383sec preferred_lft 1383sec
    inet6 fe80::20c:29ff:fefa:61c4/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
    link/ether fa:98:1e:d6:ce:ac brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever

(moawizz@moawizs-kali)-[~]
$
```

Figure 1 — Checking Kali's own IP address and network range

2. Host Discovery (Finding Live Machines on the Network)

What we did: An Nmap ping scan was run across the whole subnet to find out which IP addresses on the network were actually online and reachable, without scanning any ports yet.

What we found: Five hosts responded as "up": the Kali machine itself (192.168.32.131), the Metasploitable2 target (192.168.32.132), and three other addresses (192.168.32.1, .2 and .254) which belong to the virtual network's own gateway, DHCP service, and broadcast address rather than to a real test machine. This confirmed 192.168.32.132 as the correct target to continue testing.

```
(moawizz@moawizz-kali)-[~]
$ nmap -sn 192.168.32.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-30
Nmap scan report for 192.168.32.1 (192.168.32.1)
Host is up (0.0013s latency).
MAC Address: 00:50:56:C0:00:08 (VMware)
Nmap scan report for 192.168.32.2 (192.168.32.2)
Host is up (0.00020s latency).
MAC Address: 00:50:56:F6:4B:55 (VMware)
Nmap scan report for 192.168.32.132 (192.168.32.132)
Host is up (0.0021s latency).
MAC Address: 00:0C:29:86:0B:65 (VMware)
Nmap scan report for 192.168.32.254 (192.168.32.254)
Host is up (0.00034s latency).
MAC Address: 00:50:56:F5:7E:5A (VMware)
Nmap scan report for 192.168.32.131 (192.168.32.131)
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 2.
```

Figure 2 — Nmap host discovery scan showing all live hosts on the 192.168.32.0/24 network

3. Port and Service Scanning

1. Scanning the Target for Open Ports and Services

What we did: Nmap was used against the target (192.168.32.132) with service/version detection enabled, to find every open port and identify exactly which software and version was running behind it.

What we found: 21 open ports were found, running a wide range of old and outdated services. This matches Metasploitable2's purpose as an intentionally vulnerable practice machine.

```
(moawizz@moawizz-kali)-[~]
$ nmap -sV -T4 192.168.32.132
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-30 20:00 PKT
Stats: 0:00:47 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 95.65% done; ETC: 20:01 (0:00:02 remaining)
Stats: 0:00:59 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 95.65% done; ETC: 20:01 (0:00:03 remaining)
Nmap scan report for 192.168.32.132 (192.168.32.132)
Host is up (0.0022s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec?
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:86:0B:65 (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 63.48 seconds
```

Figure 3 — Nmap service/version scan result showing all open ports on the target

Key Open Ports Found

Port	Service	Version	Note
21	FTP	vsftpd 2.3.4	Known backdoor version
22	SSH	OpenSSH 4.7p1 (Debian)	Old version
23	Telnet	Linux telnetd	Sends data unencrypted
25	SMTP	Postfix smtpd	-
80	HTTP	Apache httpd 2.2.8	Old version
139/445	SMB	Samba smbd 3.X-4.X	Old version
512/513/514	rexec/rlogin/rsh	Old remote-access services	Unencrypted, weak auth
1524	bindshell	"Metasploitable root shell"	Nmap itself labels this a root shell
3306	MySQL	MySQL 5.0.51a	Old version
6667	IRC	UnrealIRCd	Known backdoor version

The service labelled directly by Nmap as "Metasploitable root shell" on port 1524, and the very old vsftpd (21) and UnrealIRCd (6667) versions, stood out immediately as the most concerning results — all three are well known, publicly documented backdoors, which the vulnerability scan in the next section also confirmed independently.

4. Automated Vulnerability Scanning (OpenVAS / Greenbone)

1. Starting the OpenVAS / Greenbone Service

What we did: The OpenVAS (Greenbone Vulnerability Management) service was started on Kali.

What we found: The GVM services started up correctly and the OpenVAS web dashboard became accessible in the browser.

```
(moawizz@moawizz-kali)-[~]
$ sudo systemctl enable postgresql
sudo systemctl enable redis-server@openvas
sudo systemctl enable gvm
sudo systemctl enable gsad
Synchronizing state of postgresql.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable postgresql
Created symlink '/etc/systemd/system/multi-user.target.wants/postgresql.service' -> '/usr/lib/systemd/system/postgresql.service'.
Created symlink '/etc/systemd/system/multi-user.target.wants/redis-server@openvas.service' -> '/usr/lib/systemd/system/redis-server@openvas.service'.
Created symlink '/etc/systemd/system/multi-user.target.wants/gvm.service' -> '/usr/lib/systemd/system/gvm.service'.
Created symlink '/etc/systemd/system/greenbone-security-assistant.service' -> '/usr/lib/systemd/system/gsad.service'.
Created symlink '/etc/systemd/system/multi-user.target.wants/gsad.service' -> '/usr/lib/systemd/system/gsad.service'.
```

Figure 4 — Starting the OpenVAS service

```
(moawizz@moawizz-kali)~$ sudo gvm-start
[>] Please wait for the GVM services to start.
[>] You might need to refresh your browser once it opens.
[>] Web UI (Greenbone Security Assistant): https://127.0.0.1:9392

● gsad.service - Greenbone Security Assistant daemon (gsad)
   Loaded: loaded (/usr/lib/systemd/system/gsad.service; enabled; preset: disabled)
   Active: active (running) since Thu 2026-07-30 20:12:04 PKT; 23ms ago
   Invocation: c5d1708dc7ae40e0bf55437621d5cb7f
   Docs: man:gsad(8)
         https://www.greenbone.net
   Main PID: 12610 (gsad)
   Tasks: 1 (limit: 9242)
   Memory: 2M (peak: 2M)
   CPU: 23ms
   CGroup: /system.slice/gsad.service
```

Figure 5 — GVM (Greenbone Vulnerability Manager) starting up

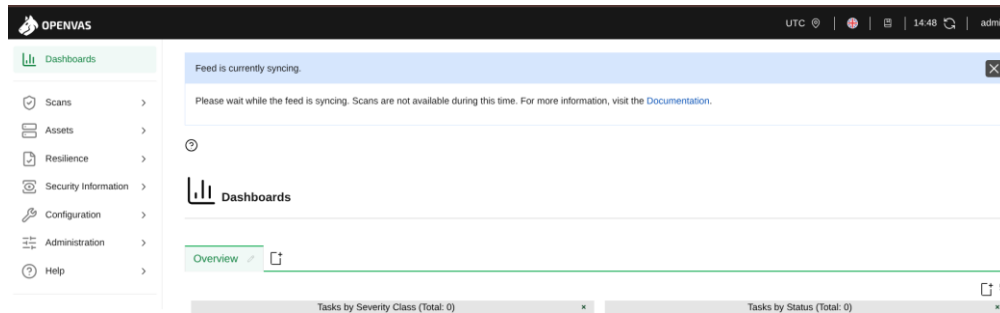


Figure 6 — OpenVAS web dashboard after login

2. Adding the Target

What we did: The target machine's IP address (192.168.32.132) was added inside OpenVAS as a new scan target.

What we found: The target was created and listed successfully in OpenVAS, ready to be scanned.

New Target

Name
Metasploitable2

Comment
Metasploitable2 Lab Machine

Hosts
☒ Manual 192.168.32.132
☐ From file

Exclude Hosts
☒ Manual
☐ From file

Allow simultaneous scanning via multiple IPs
☒ Yes ☐ No

Port List

Figure 7 — Adding Metasploitable2 (192.168.32.132) as a new target in OpenVAS

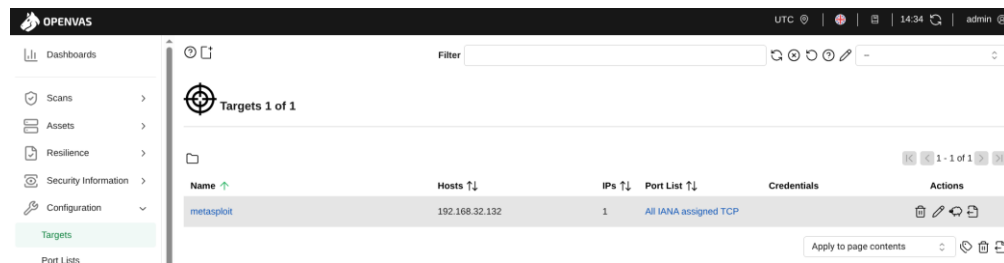


Figure 8 — Target successfully added

3. Creating and Running the Scan Task

What we did: A new scan task was created in OpenVAS using the target added above, and the scan was started.

What we found: The task was created and the scan began running against the target, using OpenVAS's full vulnerability check plugin set.

New Task

Name

Metasploitable2 Full Scan

Comment

Scan Targets

metasploit

Alerts

Schedule

--

☐ Once

Add results to Assets

☒ Yes
☐ No

Apply Overrides

☒ Yes
☐ No

Figure 9 — Creating a new scan task

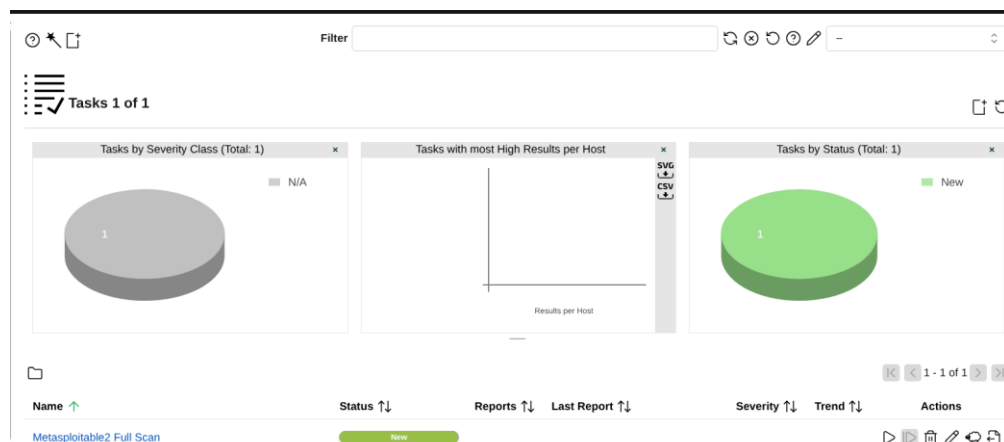


Figure 10 — Task successfully created



Figure 11 — Scan running against the target

4. Scan Results

What we did: Once the scan completed, the generated report was opened to review the findings.

What we found: The scan produced a full report listing every vulnerability found, each with a CVSS score and severity rating.



Figure 12 — Completed scan report

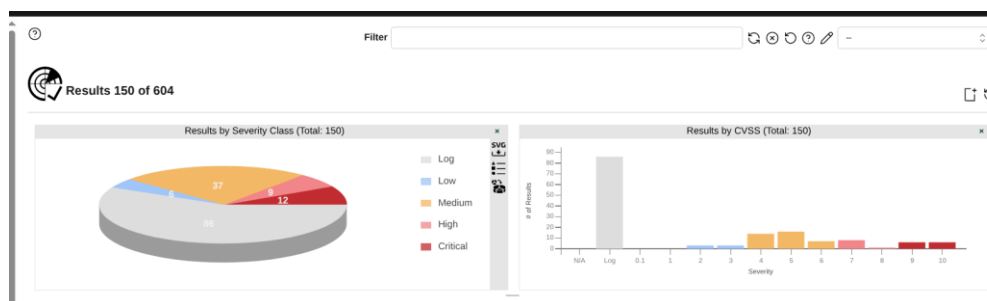


Figure 13 — Results dashboard: severity breakdown and CVSS distribution for the scan

The overall vulnerability view for this target (aggregating all results collected) showed 116 distinct vulnerabilities: 11 Critical, 8 High, 29 Medium, 5 Low, and 63 Log/informational.

Name ↓	Oldest Result ↓	Newest Result ↓	Severity ↓	QoD ↓	Results ↑	Hosts ↓
The rexec service is running	Thu, Jul 30, 2026 6:08 PM Coordinated Universal Time	Thu, Jul 30, 2026 6:08 PM Coordinated Universal Time	10.0 (Critical)	80 %	1	1
Twig < 4.2.4 Multiple XSS / Command Execution Vulnerabilities	Thu, Jul 30, 2026 6:10 PM Coordinated Universal Time	Thu, Jul 30, 2026 6:10 PM Coordinated Universal Time	10.0 (Critical)	80 %	1	1
Operating System (OS) End of Life (EOL) Detection	Thu, Jul 30, 2026 6:06 PM Coordinated Universal Time	Thu, Jul 30, 2026 6:06 PM Coordinated Universal Time	10.0 (Critical)	80 %	1	1
login Passwordless Login	Thu, Jul 30, 2026 6:06 PM Coordinated Universal Time	Thu, Jul 30, 2026 6:06 PM Coordinated Universal Time	10.0 (Critical)	80 %	1	1
Distributed Ruby (dRuby) Multiple RCE Vulnerabilities	Thu, Jul 30, 2026 6:12 PM Coordinated Universal Time	Thu, Jul 30, 2026 6:12 PM Coordinated Universal Time	10.0 (Critical)	99 %	1	1
Possible Backdoor: Ingresslock	Thu, Jul 30, 2026 6:14 PM Coordinated Universal Time	Thu, Jul 30, 2026 6:14 PM Coordinated Universal Time	10.0 (Critical)	99 %	1	1
vsftpd Compromised Source Packages Backdoor Vulnerability - Active Check	Thu, Jul 30, 2026 6:12 PM Coordinated Universal Time	Thu, Jul 30, 2026 6:12 PM Coordinated Universal Time	9.9 (Critical)	99 %	2	1
MySQL / MariaDB Default Credentials (MySQL Protocol)	Thu, Jul 30, 2026 6:12 PM Coordinated Universal Time	Thu, Jul 30, 2026 6:12 PM Coordinated Universal Time	8.8 (Critical)	95 %	1	1
DistCC RCE Vulnerability (CVE-2004-2687)	Thu, Jul 30, 2026 6:12 PM Coordinated Universal Time	Thu, Jul 30, 2026 6:12 PM Coordinated Universal Time	9.3 (Critical)	99 %	1	1
VNC Brute Force Login	Thu, Jul 30, 2026 6:10 PM Coordinated Universal Time	Thu, Jul 30, 2026 6:10 PM Coordinated Universal Time	8.0 (Critical)	70 %	1	1

Figure 14 — Vulnerabilities overview for the target: 116 total, broken down by severity

5. Severity-Ranked Vulnerability Findings

The table below lists the most significant Critical and High severity vulnerabilities identified by OpenVAS, in order of severity. These are the findings that should be prioritized first when this machine is remediated or, in a later week, used for controlled exploitation practice.

Vulnerability ↑↓	Severity ↓	QoD ↑↓	Host IP ↑↓	Name ↑↓	Location ↑↓	EPSS Score ↑↓	Percentile ↑↓	Created ↑↓
Operating System (OS) End of Life (EOL) Detection	10.0 (Critical)	80 %	192.168.32.132		general/tcp	N/A	N/A	Thu, Jul 30, 2026 6:06 PM Coordinated Universal Time
TWiki < 4.2.4 Multiple XSS / Command Execution Vulnerabilities	10.0 (Critical)	80 %	192.168.32.132		80/tcp	N/A	N/A	Thu, Jul 30, 2026 6:10 PM Coordinated Universal Time
Distributed Ruby (dRuby/DRb) Multiple RCE Vulnerabilities	10.0 (Critical)	99 %	192.168.32.132		8787/tcp	N/A	N/A	Thu, Jul 30, 2026 6:12 PM Coordinated Universal Time
rlogin Passwordless Login	10.0 (Critical)	80 %	192.168.32.132		513/tcp	N/A	N/A	Thu, Jul 30, 2026 6:06 PM Coordinated Universal Time
The rexec service is running	10.0 (Critical)	80 %	192.168.32.132		512/tcp	N/A	N/A	Thu, Jul 30, 2026 6:08 PM Coordinated Universal Time
Possible Backdoor: Ingreslock	10.0 (Critical)	99 %	192.168.32.132		1524/tcp	N/A	N/A	Thu, Jul 30, 2026 6:14 PM Coordinated Universal Time

Figure 15 — OpenVAS results, sorted by severity (page 1)

vsftpd Compromised Source Packages Backdoor Vulnerability - Active Check	9.8 (Critical)	99 %	192.168.32.132		21/tcp	N/A	N/A	Thu, Jul 30, 2026 6:12 PM Coordinated Universal Time
MySQL / MariaDB Default Credentials (MySQL Protocol)	9.8 (Critical)	95 %	192.168.32.132		3306/tcp	N/A	N/A	Thu, Jul 30, 2026 6:12 PM Coordinated Universal Time
vsftpd Compromised Source Packages Backdoor Vulnerability - Active Check	9.8 (Critical)	99 %	192.168.32.132		6200/tcp	N/A	N/A	Thu, Jul 30, 2026 6:12 PM Coordinated Universal Time
DistCC RCE Vulnerability (CVE-2004-2687)	9.3 (Critical)	99 %	192.168.32.132		3632/tcp	N/A	N/A	Thu, Jul 30, 2026 6:12 PM Coordinated Universal Time

Figure 16 — OpenVAS results, sorted by severity (page 2)

#	Vulnerability	Port	CVSS	Severity
1	Possible Backdoor: Ingreslock	1524/tcp	10.0	Critical
2	Distributed Ruby (dRuby/DRb) Multiple RCE Vulnerabilities	8787/tcp	10.0	Critical
3	TWiki < 4.2.4 Multiple XSS / Command Execution Vulnerabilities	80/tcp	10.0	Critical
4	rlogin Passwordless Login	513/tcp	10.0	Critical
5	The rexec Service is Running	512/tcp	10.0	Critical
6	Operating System (OS) End of Life (EOL) Detection	general/tcp	10.0	Critical
7	vsftpd Compromised Source Packages Backdoor Vulnerability	21/tcp, 6200/tcp	9.8	Critical
8	MySQL / MariaDB Default Credentials	3306/tcp	9.8	Critical
9	DistCC RCE Vulnerability (CVE-2004-2687)	3632/tcp	9.3	Critical

Explanation of the Most Important Findings

Possible Backdoor: Ingreslock (port 1524) — These matches what Nmap itself already flagged as a "root shell" service. A backdoor here means anyone who connects to this port is likely to be handed a command shell directly, without needing a username or password.

vsftpd Backdoor (port 21) — This exact version of the FTP server (2.3.4) is a well-documented case where the official source code was tampered with to include a hidden backdoor. It is one of the most well-known vulnerabilities associated with this practice machine.

rlogin Passwordless Login & rexec Service (ports 512/513) — These are very old remote-login services that were common in early Unix systems. They can allow a remote user to log in or run commands with no password at all, depending on configuration.

MySQL / MariaDB Default Credentials (port 3306) — The database server is reachable and accepts a default (never-changed) username and password, which would let anyone read or modify all stored data.

Operating System End of Life — The underlying Linux operating system itself is a version that no longer receives security updates, meaning every unpatched flaw ever found in it remains unfixed permanently.

6. Conclusion

Network-level reconnaissance and scanning on Metasploitable2 confirmed that the machine is running a large number of outdated and insecure services, many of which are open to the network with no authentication or with known, public backdoors. Nmap's port scan and OpenVAS's automated vulnerability scan agreed closely with each other — several of the same weaknesses (the port 1524 root shell, the vsftpd backdoor) were flagged independently by both tools, which adds confidence that these are genuine, exploitable issues rather than false alarms.

Out of 116 vulnerabilities identified, 11 were rated Critical (CVSS 9.0–10.0) and 8 High, meaning almost a fifth of all findings on this single machine are serious enough to allow an attacker to gain full remote access. The highest priority items for follow-up are the Ingreslock backdoor, the vsftpd backdoor, and the passwordless rlogin/rexec services, since each of these could give an attacker a working shell with little to no effort.

This week's work was limited to discovery, scanning, and severity triage, as required by the task. Actually, exploiting these findings to gain access is intended for a later stage of the internship, once this reconnaissance groundwork has been reviewed.